DAY 23 | POST-READ

Industry Use Cases and Agentic Security: Recap and Beyond

What we covered today, plus ideas to stretch your understanding. All topics are NEW (v4).

Prepared by **Ahmed** | linkedin.com/in/ahmed-al-imaad

Part A: Summary of today

Topic	What to remember
GenAI by industry	Same models, different data, rules and cost of being wrong.
Maturity levels	Experiment, pilot, production, scaled, agentic.
Pilot to production	Measured win, owner, evals, security review, cost model, runbook.
Do's and don'ts	Privacy, human oversight, measurable value, transparency.
Agent identity	Own identity, scoped, short-lived, revocable tokens.
Tool permissions	Deny by default; human approval for money, safety and rights.
OWASP agentic themes	Hijack, tool misuse, privilege, supply chain, memory, cascades.
Patching as a Service	Scan, triage, patch with AI, test, approve, roll out, report.
Code Modernisation as a Service	Assess, plan (rehost to rebuild), characterise, migrate, verify.

Part B: Going beyond today

1. Reachability beats raw counts

A scanner may report dozens of issues. Ask which ones are reachable from user input or the network. A medium issue on an internet-facing path can matter more than a high issue in unused code.

2. Characterisation tests

Before changing legacy code, write tests that record what it does today, including odd behaviour. They are your safety net. Change a recorded behaviour only on purpose, and write down why.

3. Strangler pattern

Put a new service in front of the old one and move one route or module at a time. Users never see a big-bang switch, and you can roll back each step.

4. Agent supply chain registers

Keep a list of every MCP server, skill, plugin, model and package an agent uses, with version, source and reviewer. It turns 'what is our exposure?' from a panic into a lookup.

5. Regulation moves

Rules such as the EU AI Act and Japan's AI Business Guidelines are being phased in and revised. Treat any date or obligation in course material as a pointer, and check the current official source with the customer's legal team. This course does not give legal advice.

Part C: Check yourself

- Name two things that must exist before a pilot goes to production.
- Why should an agent have its own identity instead of using a shared API key?
- What does 'deny by default' mean for an agent's tools?
- Why is an MCP server or skill a supply chain risk?
- What is a characterisation test, and why write it before modernising?

Part D: Practice ideas for tonight

- Run the three scanners on the starter repo and start the vulnerability report.
- Place SmartDesk on the maturity ladder and list three gaps to the next level.
- Fill in the agent permissions table in the OWASP checklist for the SmartDesk assistant.

Coming up on Day 25: small language models, token cost and optimisation, and the assignment review.

Otsukaresama deshita (お疲れ様でした): thank you for your hard work today